MODULE 39 · DOMAIN 4 - RESILIENCE, MIGRATION AND CONTINUITY

Resilient Architecture, Backup and Ransomware

Design systems that heal themselves, run containers across more than one cluster, govern backups centrally, and keep recovery copies out of an attacker's reach.

DOMAIN 4 of 5 EXAM WEIGHT 15% MODULE 39 of 52

admin@sthithapragna.com

Resilience design principles

PRINCIPLE	IN PRACTICE
Redundancy	At least two of everything, across AZs
Fault isolation	Cells, shards and accounts limit blast radius
Static stability	Pre-provision; do not need to launch to recover
Self-healing	Health checks replace what fails, automatically
Graceful degradation	Shed optional features, keep the core working

ON THE EXAM

If recovery depends on launching capacity or calling a control plane during the failure, it is not statically stable.

Self-healing building blocks

MECHANISM	HEALS
Auto Scaling health checks	Replace unhealthy instances, using ELB health
ECS service scheduler	Restart failed tasks to the desired count
Kubernetes controllers	Reschedule failed pods; probes restart containers
Route 53 health checks	Stop sending traffic to failed endpoints
Aurora and RDS Multi-AZ	Automatic database failover

ON THE EXAM

Use load balancer health checks in the Auto Scaling group, or broken-but-running instances stay in service.

One cluster, or several?

SINGLE CLUSTER, MULTI-AZ

Survives node and AZ loss

- Nodes and pods across AZs
- Simplest to operate
- One control plane, one config
- A bad upgrade affects everything

MULTIPLE CLUSTERS

Survives cluster and Region loss

- Clusters in different AZ groups or Regions
- Same workloads deployed to each via GitOps
- Traffic split by Route 53 or Global Accelerator
- Upgrade one cluster at a time

THE TIEBREAKER

A cluster is itself a failure domain. Upgrades and misconfiguration can take a whole cluster down.

Centralised backup governance

PIECE	ROLE
Backup policies in Organizations	Plans, schedules and retention pushed to accounts
Delegated administrator	Manage backups from a non-management account
Tag-based resource selection	New resources protected automatically
Cross-account and cross-Region copy	Copies outside the source account and Region
Backup Audit Manager	Reports on compliance with backup controls
Restore testing	Scheduled restores prove backups work

ON THE EXAM

Teams cannot opt out of a backup policy attached to their OU.

Immutability controls

CONTROL	PROTECTS	STRONGEST MODE
S3 Object Lock	Object versions in a bucket	Compliance: nobody can delete, even root
EBS snapshot lock	Individual EBS snapshots	Compliance, after a cooling-off period
Backup Vault Lock	All recovery points in a vault	Compliance: lock itself immutable
Logically air-gapped vault	Backups isolated from the source account	Compliance-locked, AWS-isolated

ON THE EXAM

Governance mode can be bypassed with permission. Compliance mode cannot be bypassed by anyone.

Logically air-gapped vaults

- **Compliance-locked** vault, isolated from the account that created the backups.
- **Shareable to a recovery account** to restore if the source is compromised.
- **Multi-party approval** restores access even if the owning account is lost.
- **Malware scanning** of recovery points with GuardDuty before restore.
- **Covers** EC2, EBS, RDS, Aurora, S3, FSx, EKS and more.

> ON THE EXAM
>
> Admin credentials stolen in the workload account: recovery copies in a locked, air-gapped vault elsewhere.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Attackers may hold admin credentials	Compliance-mode locks, air-gapped vault
Every account backed up, no opt-out	Organizations backup policies
WORM records, even root cannot delete	S3 Object Lock compliance mode
Protect specific EBS snapshots	EBS snapshot lock
Is this backup clean before restoring?	Malware scanning, restore testing
A bad cluster upgrade took everything down	Multiple clusters

ON THE EXAM

Ransomware answers assume the attacker is an administrator. Design for that.

> After a ransomware incident at a competitor, Meridian Freight assumes an attacker could gain administrator access to any workload account. Today, backups are stored in each workload account.
>
> Backups must survive such an attack, and recovery must remain possible even if a workload account is lost.

What should the solutions architect recommend?

A. Copy backups to a logically air-gapped vault, compliance-locked and shared with a recovery account, with multi-party approval configured

B. Add an IAM policy in each workload account denying backup deletion

C. Enable S3 versioning on the backup bucket

D. Take snapshots twice as often

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Air-gapped vault with MPA

Out of the attacker's reach, locked, restorable elsewhere.

B IAM deny

An administrator can remove the policy.

C Versioning

Versions can be deleted by an administrator.

D More snapshots

Still in the compromised account.

THE SIGNAL

Assume the admin is compromised: isolate, lock in compliance mode, restore elsewhere.

> Meridian Freight's 200 accounts back up inconsistently; some teams have no backups at all. Policy says every RDS database and EBS volume tagged backup=daily needs daily backups kept 35 days, plus a copy in the central backup account.
>
> Teams must not be able to remove the arrangement.

What should the solutions architect implement?

A Ask each team to create AWS Backup plans

B Data Lifecycle Manager policies in each account

C AWS Backup policies in Organizations, attached to the OUs, with tag-based selection and cross-account copy, managed by a delegated administrator

D A Lambda function in each account taking snapshots

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Team-created plans

The current inconsistency, repeated.

B DLM per account

EBS only, not RDS, and removable by teams.

C Organizations backup policies

Central, tag-driven, cross-account, not removable by teams.

D Lambda per account

Custom code, and removable by account admins.

THE SIGNAL

Every account, no opt-out, central copies: backup policies in Organizations.

> A regulator requires Meridian Freight to keep customs declaration files in S3 for seven years in write-once, read-many form.
>
> Nobody, including the root user and AWS account administrators, may delete or overwrite them during that period.

What should the solutions architect configure?

A. S3 Object Lock in governance mode

B. MFA Delete on a versioned bucket

C. A bucket policy denying s3:DeleteObject

D. S3 Object Lock in compliance mode with a seven-year default retention

◆ PAUSE AND DECIDE

What should the solutions architect configure?

A **Governance mode**
Users with bypass permission can delete.

B **MFA Delete**
The root user with MFA can still delete.

C **Bucket policy**
An administrator can change the policy.

D **Compliance mode**
No one can delete or shorten retention, root included.

THE SIGNAL

Even root cannot delete: Object Lock compliance mode.

> During an active security incident, Meridian Freight's responders want to make sure the latest EBS snapshots of its core database servers cannot be deleted for the next 30 days.
>
> The snapshots are not managed by AWS Backup, and protection should apply to those specific snapshots.

What should the solutions architect do?

A Copy the snapshots to S3 Glacier

B Apply EBS snapshot lock in compliance mode with a 30-day duration to those snapshots

C Tag the snapshots do-not-delete

D Turn on Recycle Bin with a one-day retention

◆ PAUSE AND DECIDE

What should the solutions architect do?

A **Copy to Glacier**

Snapshots cannot simply be copied to your own Glacier storage.

B **EBS snapshot lock**

Per-snapshot, compliance mode, fixed duration.

C **Tag**

A label, not a control.

D **Recycle Bin, one day**

Recovers deleted snapshots briefly; does not prevent deletion.

THE SIGNAL

Lock specific EBS snapshots, outside AWS Backup: EBS snapshot lock.

> Meridian Freight is about to restore servers from AWS Backup after a ransomware attack. The team suspects some recent recovery points may already contain the malware.
>
> They want to identify clean recovery points before restoring into production.

What should the solutions architect recommend?

A. Restore the newest recovery point and scan it in production

B. Restore the oldest recovery point available

C. Scan recovery points with GuardDuty Malware Protection for AWS Backup, and restore the newest clean one into an isolated environment first

D. Ask application owners which date to restore from

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Newest, in production

May reinfect production.

B Oldest

Probably clean, but loses far more data than needed.

C Scan, then isolated restore

Newest clean point, verified before production.

D Ask owners

A guess, not evidence.

THE SIGNAL

Find the newest clean point by scanning, and restore it somewhere isolated first.

A faulty add-on upgrade on Meridian Freight's single production EKS cluster took every service offline for three hours, although all three AZs were healthy.

The platform team wants to prevent one cluster problem from taking down production again, and also survive a Regional outage.

What should the solutions architect recommend?

A. Run production on two EKS clusters in different Regions, deployed identically through GitOps, with traffic shared by Global Accelerator, and upgrade one cluster at a time

B. Add more node groups to the existing cluster

C. Spread the existing cluster across more Availability Zones

D. Disable cluster add-on upgrades permanently

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A **Two clusters, two Regions**
A cluster or Region failure leaves the other serving.

B **More node groups**
Still one cluster, one failure domain.

C **More AZs**
The AZs were healthy; the cluster was the problem.

D **No upgrades**
Swaps an outage for a security risk.

THE SIGNAL

The cluster failed while the AZs were fine: the cluster is a failure domain. Run more than one.

What to carry out of this module

- **Redundant, isolated, statically stable, self-healing** designs.
- **Clusters are failure domains**; run more than one for critical services.
- **Backup policies in Organizations** with a delegated administrator.
- **Compliance-mode locks**: Object Lock, snapshot lock, Vault Lock.
- **Air-gapped vaults, MPA, malware scans** for ransomware recovery.

> ON THE EXAM
>
> Assume the administrator is compromised, and design recovery so it still works.